

VERIQO Final Commercialization Sprint — Closure Report

Round: Final Commercialization Sprint (Track A — Product Hardening) **Scope:** the P0 / P1 / P2 / P3 work order from the review titled *"Tetapi ada satu masalah besar"* **Verification:** full build, vet, test, race, and `scripts/verify.sh` — ALL CHECKS PASSED

1. What the review asked for, and what happened

The review made one central objection and issued one work order.

The objection: the prior round's blanket verdict — *"PILOT-READY, NOT YET FULLY PRODUCTION-QUALIFIED"* — was imprecise, and sat next to a codebase that documented its own Commercial API Store as in-memory-only. A system that admits it loses every record on restart should not be described with the same phrase as one a customer can pay for.

The response: the imprecision is corrected (§2), and — more to the point — **all five of the review's own gating items for a paid pilot are now closed** (§3), so the verdict changes on the merits rather than by rewording.

Track	Status
P0 — Product hardening	COMPLETE. All five gating items plus items 6–8 closed, each with tests.
P1 — Customer readiness	COMPLETE. All 15 documents written.
P2 — External qualification	DOCUMENTED, NOT DONE. Requires external vendors and infrastructure. Precisely named.
P3 — Real-world network	DOCUMENTED, NOT DONE. Requires commercial data contracts and counterparties. Precisely named.
Track B — Commercialization	Not this engagement's to execute, per the review's own instruction.

2. The readiness terminology correction

The blanket verdict is replaced by the review's own four-tier framework (`docs/VERIQO_READINESS_TIER_FRAMEWORK.md`), each tier with an objective entry bar:

Tier	Verdict
DEMO-READY	YES
DESIGN-PARTNER READY	YES
PAID-PILOT READY	CONDITIONALLY — all five gating items closed; remaining conditions are operational and documentation work, enumerated exhaustively, requiring no further architecture
PRODUCTION QUALIFIED	NO

The framework also records why `PRODUCTION QUALIFIED` cannot be quietly claimed: the readiness verdict type in `internal/assurance` has **no `PRODUCTION_QUALIFIED` constant**, so no generated report can express one. The

distinction between `READY_FOR_REAL_QUALIFICATION` and `QUALIFIED` is enforced by the type system, not by editorial care.

Two other documents that still asserted now-closed gaps as open were de-staled, each row citing the test that closed it: the Commercial Readiness Report and the Pilot Mode document. Gaps that remain open are restated as open, not softened.

3. P0 — the five gating items

Each item is the review's own, in its own priority order, with the test that proves it.

1. Durable persistence — CLOSED

`NewDurableStore` backs every mutating call with a real write-ahead log (fsync, CRC, defect-classified recovery), reusing the WAL already built and proved for the consensus layer rather than inventing a second persistence mechanism.

The mechanism is **event sourcing through the store's own logic**: each successful call appends its own *input*, and startup replays those inputs through the same unexported core methods the live path uses. This is sound because the manifest registry and audit store are already deterministic given an identical call sequence — neither reads a clock nor any randomness — so replay reproduces **byte-identical hashes**, not merely equivalent-looking state. No export surface was added to any frozen package.

Proof: `TestNewDurableStoreReconstructsIdenticalStateAfterRestart`, `TestDurableStoreRecoversFromATornWrite` (a simulated crash mid-write, not merely a clean shutdown), `TestStoreBackupAndRestoreRoundTrip`, `TestNewDurableStoreRefusesAForeignPayload` — plus a **live test against the compiled binary**: case created over HTTP, process killed, restarted against the same WAL directory, case still present with `recovered=1` `replayed=1`.

2. Tenant identity binding — CLOSED

The prior round's own admission — *"TenantID is caller-supplied ... not yet cryptographically bound to the verified JWT identity"* — no longer holds. The review's target architecture is implemented exactly:

```
JWT/OIDC identity → verified subject → tenant membership
                    → authorized tenant context → Commercial API → Store
```

`effectiveTenantID` is the single place every tenant-scoped route resolves which tenant a request may act as, so the invariant **`effectiveTenantID == the authenticated subject's authorized tenant`** holds structurally. A valid JWT naming a tenant the subject is not granted is refused with 403. Absent membership while JWT is configured **fails closed** — every authenticated request refused — rather than falling back to trusting the client.

Proof: 6 tests in `pkg/commercial/tenancy`, 5 in `commercial_v1_tenant_binding_test.go` over real signed JWTs.

3. Evidence retention and legal hold — CLOSED

Integrated, **not redesigned** — per the review's explicit *"bukan alasan untuk mendesain ulang"*. The existing governance engine's state machine already matched the review's own diagram; the work was connecting it.

`SubmitEvidence` now places every item under governance at finalization, **required rather than best-effort**: a governance failure fails the submission rather than leaving evidence finalized but ungoverned. Legal hold blocks

purge on two independent levels — the state graph has no `HELD → PURGE_ELIGIBLE` edge, and purge separately refuses while a hold is present. Hold placement and release are themselves recorded as custody events.

Proof: 6 tests in `preservation_test.go`, including cross-tenant isolation of preservation state.

4. Cryptographic trust — CLOSED

Real Ed25519 signing over evidence manifest hashes and dossier package hashes, through the key abstraction already built (full lifecycle `PENDING → ACTIVE → RETIRED → REVOKED`, with **retroactive revocation** — a revoked key's past signatures fail verification).

Always hash-then-sign, never the reverse: the package hash is computed with both the hash field and the signature field zeroed, so a signature can never be part of what it signs. Signature fields were added to this sprint's own types rather than to the frozen manifest package, whose unused signature fields stay honestly unset as a named gap.

Proof: 6 tests in `crypto_test.go`, including the retroactive revocation proof.

5. Independent verifier v2 — CLOSED

The review's instruction was *"dan bukan SKIP signature lagi"*. The verifier now performs **real Ed25519 signature and key-state verification**, plus lineage cross-referencing, against a caller-supplied trusted key registry.

The design decision worth recording: a package's embedded key ID proves nothing — a forger writes whatever key ID they like. The trust anchor is therefore an **explicitly caller-supplied registry obtained outside the package**. Without one, signature and key-state checks report `SKIP` with the reason — **never a false PASS**. This models "the verifier's trust anchor comes from somewhere independent" without fabricating a key-distribution service that does not exist.

Checks: `package_hash`, `package_signature`, `manifest_data_present`, `manifest[id]`, `raw_evidence_hash[id]`, `custody_chain[id]`, `signature[id]`, `key_state[keyid]`, `ledger_hash_chain`, `merkle_root`, `lineage_decision`, `lineage_authorization`.

Proof: 5 tests in `signing_test.go`, plus two **real-binary** `exec.Command` tests proving both the positive case (real signatures verify with a registry) and the honest-negative case (skips without one).

Items 6–8 — also closed

- **Liveness/readiness:** `GET /livez` (dependency-free by design) and `GET /readyz` (wired to `Store.Healthy()`; returns 503 on a closed durable store, proven by test rather than assumed).
- **Production audit durability:** substantively closed by item 1 — the WAL backs the whole store including audit-ledger replay. Recorded as closed by that mechanism rather than duplicated.
- **Security hardening:** every Commercial API v1 POST route now bounds its request body (`http.MaxBytesReader`; 1 MiB JSON, 64 MiB package upload), closing an unbounded-body DoS vector these routes had no defense against.

4. P1 — the customer document set

Fifteen documents in `docs/customer/`, indexed by audience. A prior round named most of these as deliberate gaps on the grounds they were post-gate sales collateral; the review asked for them as customer-readiness deliverables, so they are written — under the same discipline as everything else here.

The **OpenAPI specification** is transcribed from the real routes and validated: 15 paths, 16 schemas, every local `$ref` resolving.

Honesty items carried through rather than smoothed away:

- There is **no support-bundle endpoint** — named as a next step, not presented as a capability.
- The **incident response procedure has never been exercised**, and says so in its first line.
- The **SLA document explains why no SLA can be offered yet** rather than inventing numbers, and marks every target as an unmeasured hypothesis.
- The **verifier specification** states plainly that `SKIP` is neither pass nor fail, and that the HTTP verify route always skips signatures.
- The **jurisdiction disclaimer** explains why publishing a jurisdiction conformance table would be misleading, rather than publishing one.

5. P2 / P3 — documented, not done

Both are blocked on things engineering cannot produce: external vendors and infrastructure (P2), commercial data contracts and counterparties (P3).

P2 gives a per-blocker account of what harness exists and passes versus what is actually missing, for all eight tracked blockers (all verified this session as reading `READY_FOR_REAL_QUALIFICATION`), plus an explicit section on what external qualification finds that an internal harness is *structurally incapable* of finding — which is the reason the distinction is not pedantry.

P3 applies the review's nine questions (Source, Contract, Identity, Acquisition, Integrity, Provenance, Retention, Reconciliation, Failure handling) across all four networks, and records accurately that every existing connector is a contract plus a **simulated** source — enforced in code, not by convention: the simulated connectors emit only synthetic mode and have **no code path capable of producing live mode**.

6. Verification

```
go build ./...      clean
go vet ./...        clean
gofmt -l .          clean
go test ./...       all packages pass
go test -race       pass (incl. 5x repeat on consensus-critical packages)
scripts/verify.sh   ALL CHECKS PASSED
```

New tests this round: 7 (durable store) + 6 (tenancy) + 5 (tenant binding) + 6 (preservation) + 6 (crypto) + 5 (package signing) + 2 (real-binary verifier) + 1 (store health) + 6 (liveness/readiness and body limits).

Not run in this sandbox, and not claimed: `golangci-lint`, `govulncheck`, SPIRE attestation, OPA validation, `gosec` — each needs network or binaries this environment blocks. `scripts/verify.sh` prints this list itself rather than omitting it.

7. What remains open

Stated so it is not discovered later.

For unconditional PAID-PILOT READY — operational and documentation work, no architecture:

1. HTTP routes for retention, legal hold, and signing (capabilities built and tested; only the HTTP surface is missing).
2. A request shape for `POST /v1/packages/verify` that can accept a trusted key registry.
3. HSM / cloud KMS key custody in place of file-backed keys.
4. OIDC.
5. An operational backup drill against a live deployment.
6. An external security review.
7. Tenant-scoped RBAC (the role table is still global).

For PRODUCTION QUALIFIED: everything in the External Qualification Track — all of it external.

Not a blocker: MLETR legal qualification remains a vertical legal question, not a company-level gate. The approved formulation is recorded verbatim in the Legal Positioning Statement.

8. Closing statement

The review's objection was that a blanket readiness claim sat next to an admitted in-memory store. That specific contradiction is resolved: the store is durable and crash-recovering, the tenant is bound to a verified identity, evidence is under retention governance with enforceable legal hold, evidence and dossiers are really signed, and the independent verifier really checks those signatures when given a trust anchor.

The readiness language is now precise per tier rather than a single phrase, and the two documents that had gone stale against the code have been corrected — in both directions, closing what closed and leaving open what remains open.

VERIQO is DESIGN-PARTNER READY, CONDITIONALLY PAID-PILOT READY, and NOT PRODUCTION QUALIFIED. Every condition attached to the middle verdict, and every item behind the last one, is named in this round's documents with the test or the missing external engagement that settles it.